

Securing the AI Era

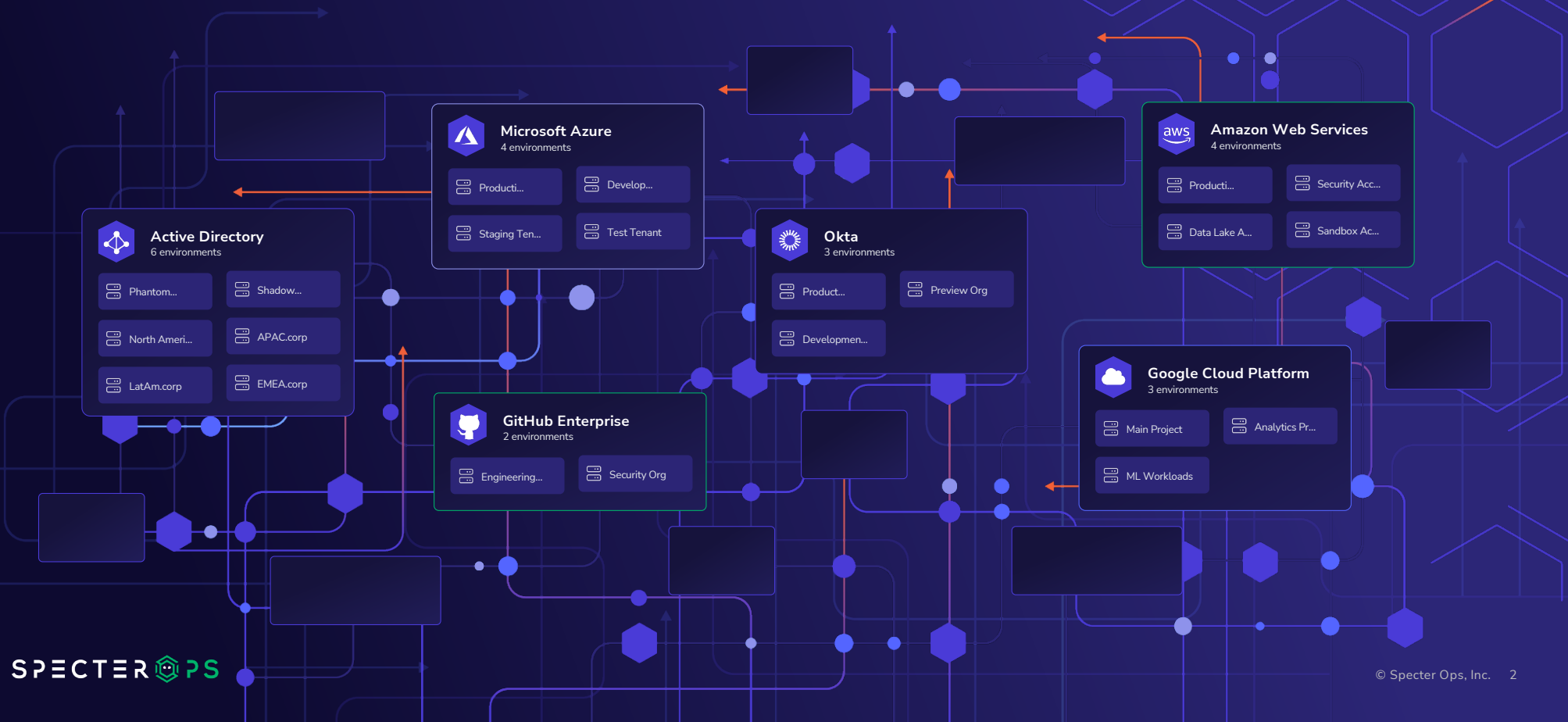
The Next Evolution of Identity Attack Path Management

Justin Kohler
Chief Product Officer

Jared Atkinson
Chief Technology Officer



Attackers don't see isolated systems, they see interconnected set of relationships



AI adoption creates an explosion in risk



AI is compressing timelines

Vuln-to-exploit window is shrinking

INTRUSION ERA

TIME FROM FOOHOLD TO IMPACT

Traditional intrusion

Manual recon & chaining

Weeks

Cloud-era intrusion

Token theft, federated traversal

Hours

AI-assisted intrusion

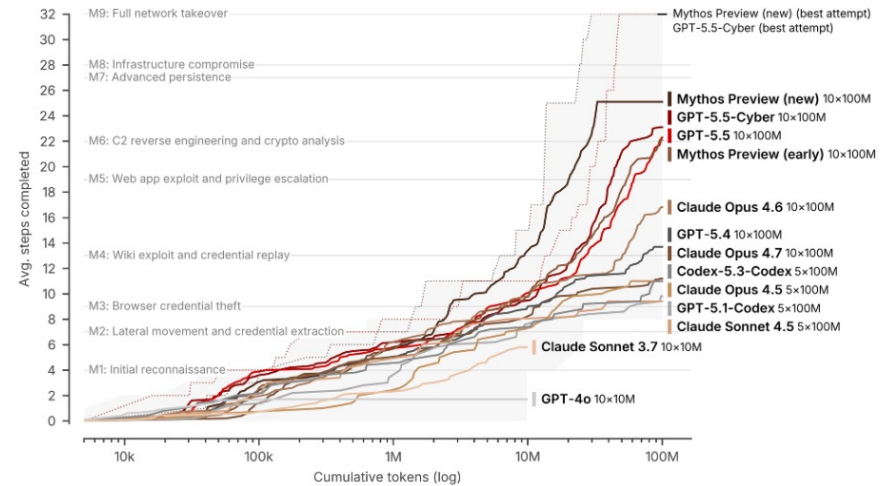
Machine-speed exploit and chains

Machine speed

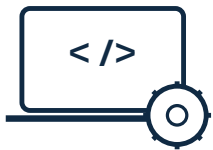
Response window is collapsing

Completed steps on "The Last Ones" per spent tokens

AI SECURITY INSTITUTE

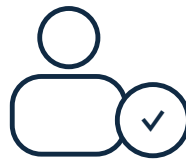


Security tools see isolated findings



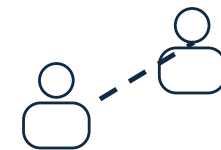
Can modify a workload

MEDIUM



Workload runs as a privileged role

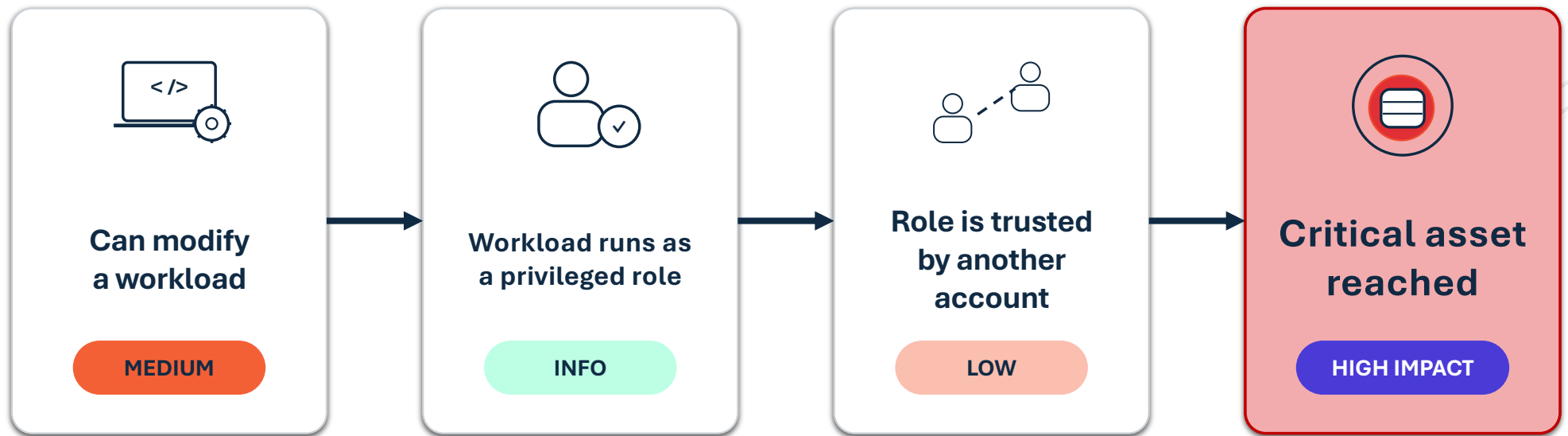
INFO



Role trusted by another account

LOW

Attackers see the path



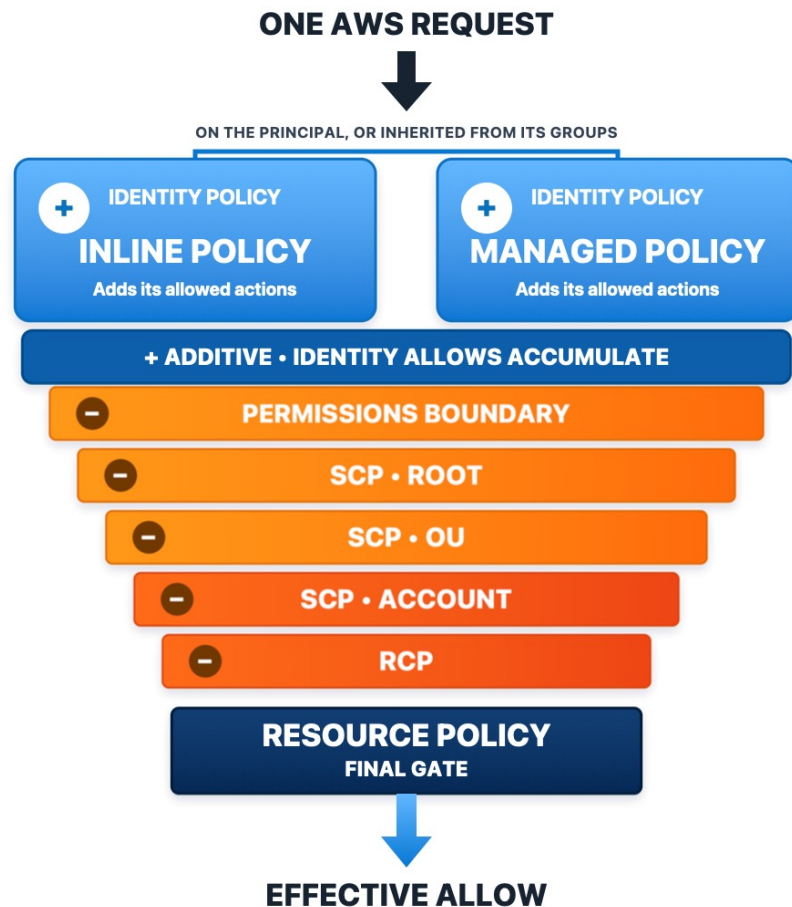
Attack Paths in AWS

The AWS Problem

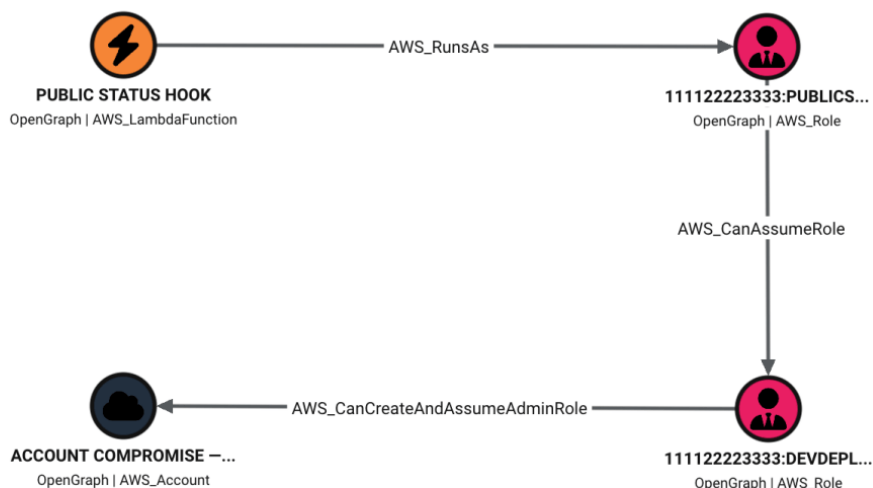
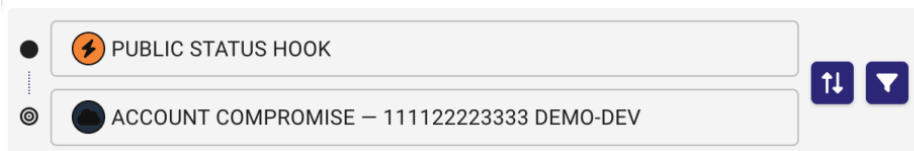
The core question has four parts:

Can this principal, perform this action, on this resource, in this request context?

Even for one of those parts, the answer gets assembled out of a stack of policy documents that live in ***different places*** and ***different teams*** usually own them.



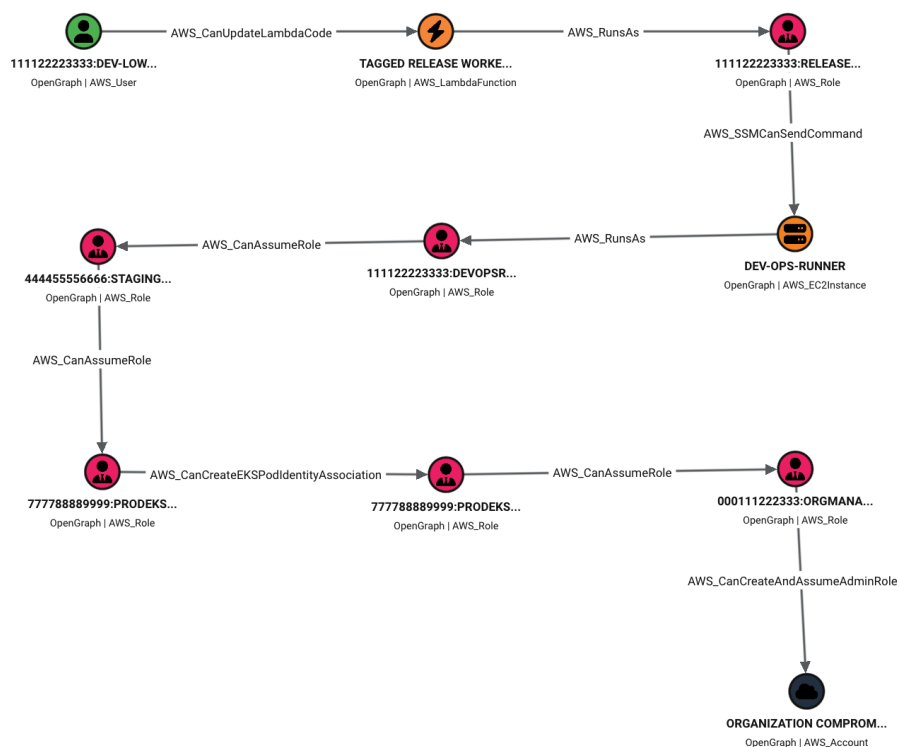
Same Account Compromise



- Internet-facing Lambda enables code execution and exposes **PublicStatusLambdaRole** credentials.
- That role can assume **DevDeploymentRole**.
- **DevDeploymentRole** can create and assume an administrator role.

Result: full AWS account takeover.

Cross-Account Path to Organization Compromise



- Dev user can update code only on Lambda functions tagged **Environment=dev**.
- Lambda code execution exposes **ReleaseWorkerRole**, enabling access to the EC2 runner.
- Runner execution exposes **DevOpsRunnerRole** credentials through IMDS.
- Conditional role assumptions bridge staging, production, and management accounts.
- Production EKS privileges enable access to an admin workload identity.
- Final escalation enables administrator access in the management account.

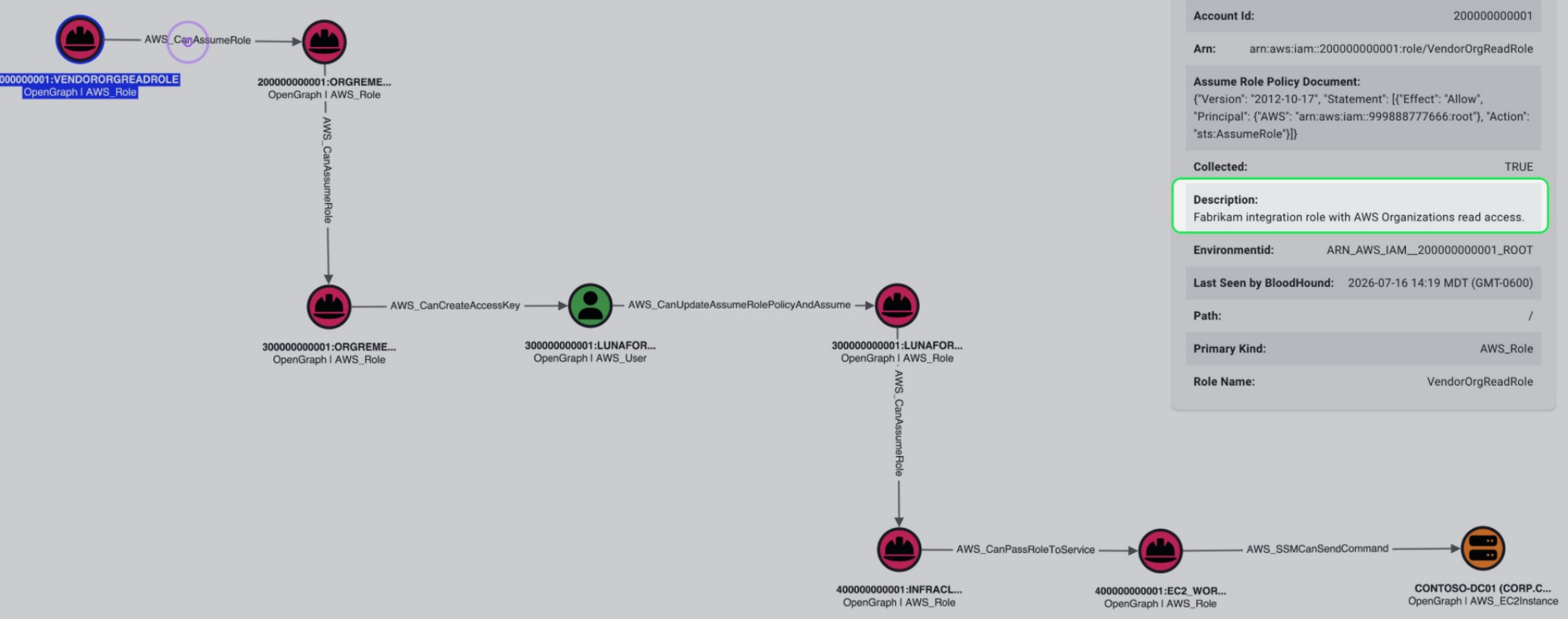
Result: organization-wide compromise.

200000000001:VENDORORGREADROLE

200000000001:VENDORORGREADROLE

CONTOSO-DC01 (CORP.CONTOSO.COM)

CONTOSO-DC01 (CORP.CONTOSO.COM)



200000000001:VENDORORGREADROLE

Object Information

Node Type:

AWS_Role

Object ID:

ARN_AWS_IAM_200000000001_ROLE/VENDORORGREADROLE

Account Id:

200000000001

Arn:

arn:aws:iam::200000000001:role/VendorOrgReadRole

Assume Role Policy Document:

{
 "Version": "2012-10-17",
 "Statement": [{
 "Effect": "Allow",
 "Principal": {"AWS": "arn:aws:iam::999888777666:root"},
 "Action": "sts:AssumeRole"
 }]
}

Collected:

TRUE

Description:

Fabrikam integration role with AWS Organizations read access.

EnvironmentId:

ARN_AWS_IAM_200000000001_ROOT

Last Seen by BloodHound:

2026-07-16 14:19 MDT (GMT-0600)

Path:

/

Primary Kind:

AWS_Role

Role Name:

VendorOrgReadRole

SEARCH

PATHFINDING

CYPHER

200000000001:VENDORORGREADROLE

CONTOSO-DC01 (CORP.CONTOSO.COM)

200000000001:VENDORORGREADROLE

200000000001:ORGREME...

300000000001:ORGREME...

300000000001:LUNAFOR...

300000000001:LUNAFOR...

400000000001:INFRACL...

400000000001:EC2_WOR...

CONTOSO-DC01 (CORP.C...

AWS_CanAssumeRole

AWS_CanAssumeRole

AWS_CanCreateAccessKey

AWS_CanUpdateAssumeRolePolicyAndAssume

AWS_CanAssumeRole

AWS_CanPassRoleToService

AWS_SSMCanSendCommand

Relationship Information

Source Node:200000000001:VENDORORGREADROLE

Target Node:200000000001:ORGREME...

Allow Sources:
arn:aws:iam::200000000001:role/VendorOrgReadRole
(sts:AssumeRole on OrgRemediationRole)

Is Traversable:TRUE

Last Seen by BloodHound:
2026-07-16 14:19 MDT (GMT-0600)

The edge AWS_CanAssumeRole does not have any additional contextual information at this time.

Even though the role appears read-only, it can assume an internal org remediation role in the security account

Hide Labels

Layout

Export

Search

Hide Labels

Layout

Export

Search

SEARCH

PATHFINDING

CYPHER

200000000001:VENDORORGREADROLE

CONTOSO-DC01 (CORP.CONTOSO.COM)

200000000001:VENDORORGREADROLE
OpenGraph | AWS_Role

AWS_CanAssumeRole

200000000001:ORGREMIATIONROLE
OpenGraph | AWS_Role

AWS_CanAssumeRole

300000000001:ORGREME...
OpenGraph | AWS_Role

AWS_CanCreateAccessKey

300000000001:LUNAFOR...
OpenGraph | AWS_User

AWS_CanUpdateAssumeRolePolicyAndAssume

300000000001:LUNAFOR...
OpenGraph | AWS_Role

AWS_CanAssumeRole

400000000001:INFRACL...
OpenGraph | AWS_Role

AWS_CanPassRoleToService

400000000001:EC2_WOR...
OpenGraph | AWS_Role

AWS_SSMCanSendCommand

CONTOSO-DC01 (CORP.C...
OpenGraph | AWS_EC2Instance

Remediation roles across the AWS organization can assume one another when the org ID matches. This effectively lets the attacker pivot from the security account into other accounts

200000000001:ORGREMIATIONROLE

Object Information

Node Type:AWS_Role

Object ID:ARN_AWS_IAM__200000000001_ROLE/ORGREMIATIONROLE

Account Id:200000000001

Arn:arn.aws:iam::200000000001:role/OrgRemediationRole

Collected:TRUE

Description:Org-wide remediation role (deployed with the same name in every account).

EnvironmentId:ARN_AWS_IAM__200000000001_ROOT

Last Seen by BloodHound:2026-07-16 14:19 MDT (GMT-0600)

Path:/

Primary Kind:AWS_Role

Role Name:OrgRemediationRole

Hide Labels

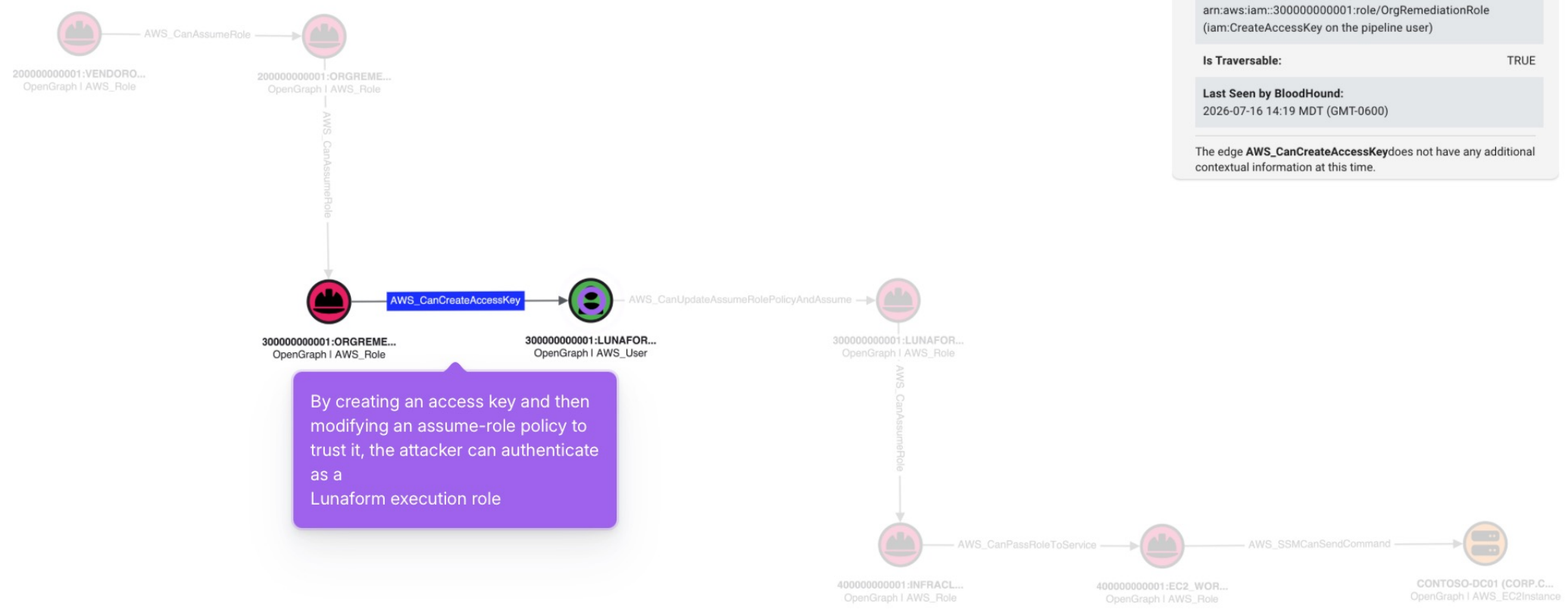
Layout

Export

Search

200000000001:VENDORORGREADROLE

200000000001:CONTOSO-DC01 (CORP.CONTOSO.COM)



AWS_CanCreateAccessKey

Relationship Information

Source Node:300000000001:ORGREMIATIONROLE

Target Node:300000000001:LUNAFORM-PIPELINE

Allow Sources:
arn:aws:iam::300000000001:role/OrgRemediationRole
(iam.CreateAccessKey on the pipeline user)

Is Traversable:TRUE

Last Seen by BloodHound:
2026-07-16 14:19 MDT (GMT-0600)

The edge **AWS_CanCreateAccessKey** does not have any additional contextual information at this time.

SEARCH

PATHFINDING

CYPHER

200000000001:VENDORORGREADROLE

CONTOSO-DC01 (CORP.CONTOSO.COM)

200000000001:VENDORORGREADROLE

200000000001:ORGREME...

300000000001:ORGREME...

300000000001:LUNAFORM-PIPELINE

300000000001:LUNAFOR...

400000000001:INFRACL...

400000000001:EC2_WOR...

CONTOSO-DC01 (CORP.C...

AWS_CanAssumeRole

AWS_CanAssumeRole

AWS_CanAssumeRole

AWS_CanCreateAccessKey

AWS_CanUpdateAssumeRolePolicyAndAssume

AWS_CanAssumeRole

AWS_CanPassRoleToService

AWS_SSMCanSendCommand

OpenGraph | AWS_Role

OpenGraph | AWS_Role

OpenGraph | AWS_Role

OpenGraph | AWS_User

OpenGraph | AWS_Role

OpenGraph | AWS_Role

OpenGraph | AWS_Role

OpenGraph | AWS_EC2Instance

300000000001:LUNAFORM-PIPELINE

Object Information

Node Type:

AWS_User

Object ID:

ARN_AWS_IAM__300000000001_USER/LUNAFORM-PIPELINE

Account Id:

300000000001

Arn:

arn:aws:iam::300000000001:user/lunaform-pipeline

Collected:

TRUE

Description:

CI/CD service user that manages (can modify) the Lunaform execution role.

Environmentid:

ARN_AWS_IAM__300000000001_ROOT

Last Seen by BloodHound:

2026-07-16 14:19 MDT (GMT-0600)

Path:

/

Primary Kind:

AWS_User

User Name:

lunaform-pipeline

Hide Labels

Layout

Export

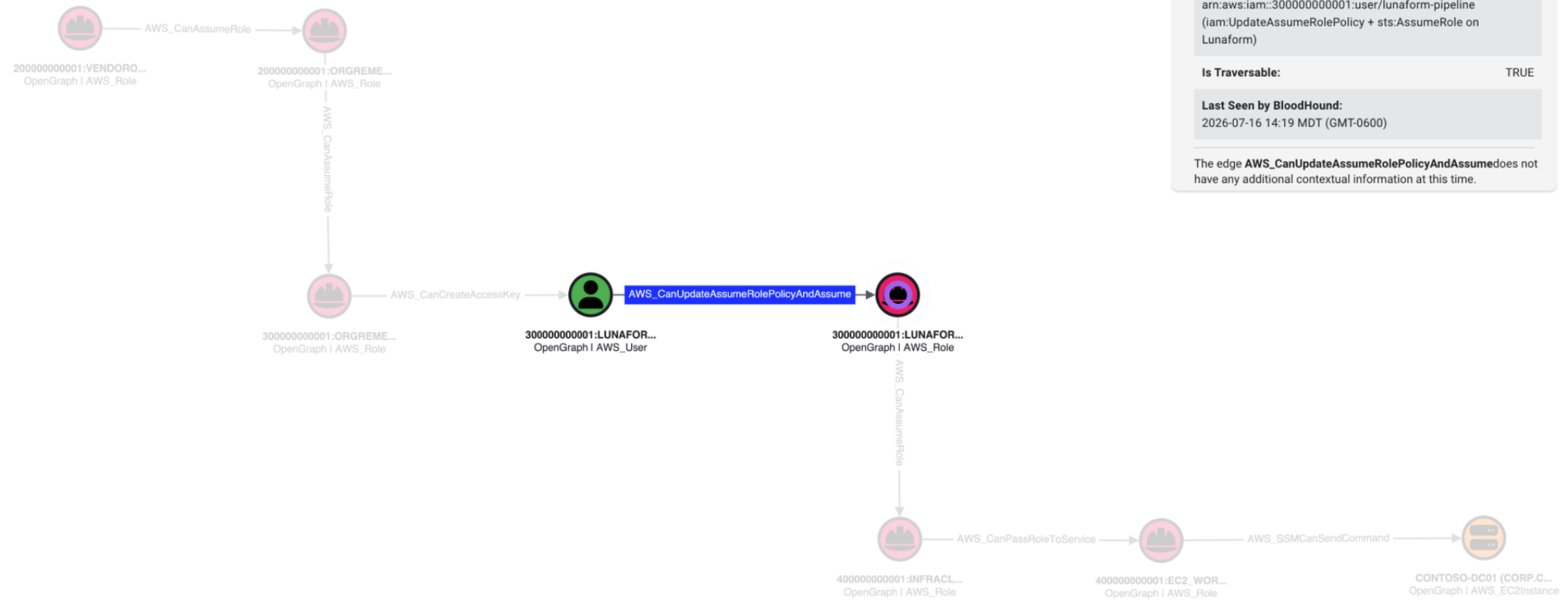
Search

200000000001:VENDORORGREADROLE

200000000001:VENDORORGREADROLE

↑↓

▼



AWS_CanUpdateAssumeRolePolicyAndAssume

Relationship Information

Source Node:

300000000001:LUNAFORM-PIPELINE

Target Node:

300000000001:LUNAFORMEXECUTIONROLE

Allow Sources:

arn:aws:iam::300000000001:user/lunaform-pipeline
(iam:UpdateAssumeRolePolicy + sts:AssumeRole on Lunaform)

Is Traversable:

TRUE

Last Seen by BloodHound:

2026-07-16 14:19 MDT (GMT-0600)

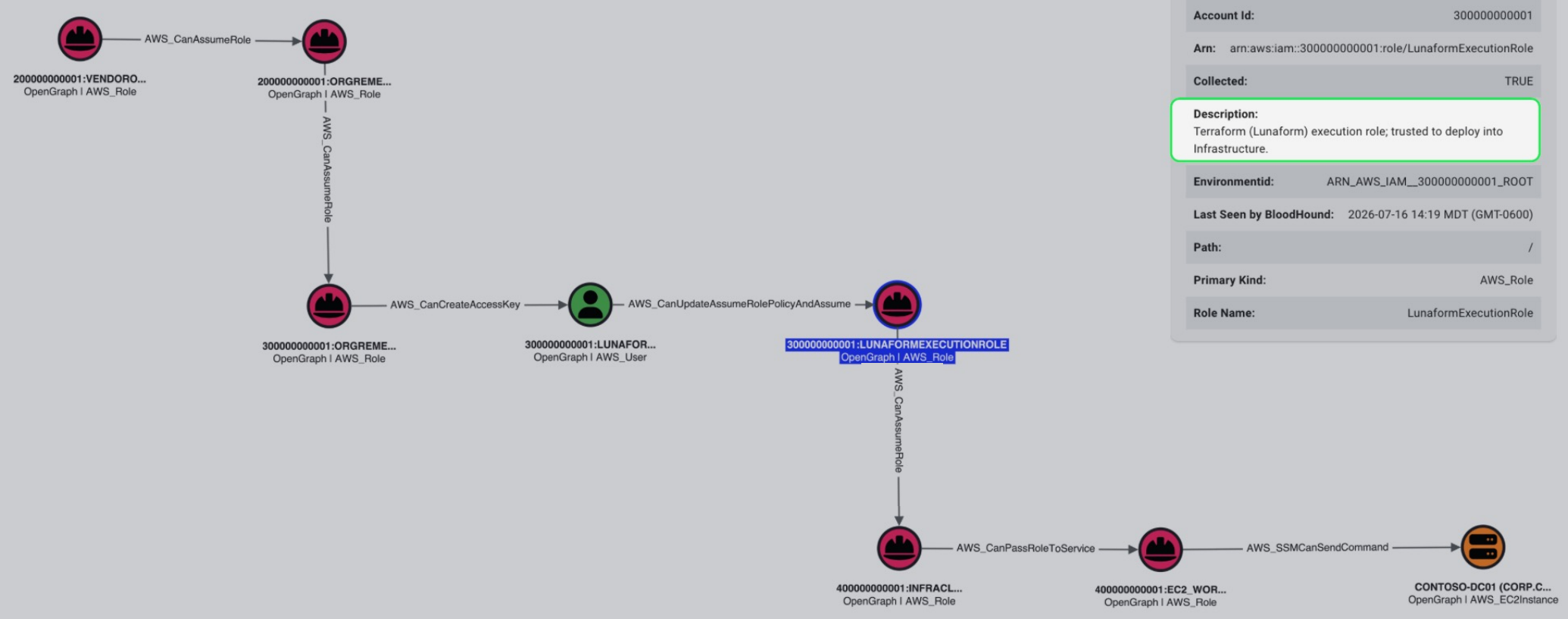
The edge AWS_CanUpdateAssumeRolePolicyAndAssumedoes not have any additional contextual information at this time.

200000000001:VENDORORGREADROLE

200000000001:VENDORORGREADROLE

CONTOSO-DC01 (CORP.CONTOSO.COM)

CONTOSO-DC01 (CORP.CONTOSO.COM)



300000000001:LUNAFORMEXECUTIO... x

Object Information

Node Type:

AWS_Role

Object ID:

ARN_AWS_IAM__300000000001_ROLE/LUNAFORMEXECUTIO...

Account Id:

300000000001

Arn:

arn:aws:iam::300000000001:role/LunaformExecutionRole

Collected:

TRUE

Description:

Terraform (Lunaform) execution role; trusted to deploy into Infrastructure.

Environmentid:

ARN_AWS_IAM__300000000001_ROOT

Last Seen by BloodHound:

2026-07-16 14:19 MDT (GMT-0600)

Path:

/

Primary Kind:

AWS_Role

Role Name:

LunaformExecutionRole

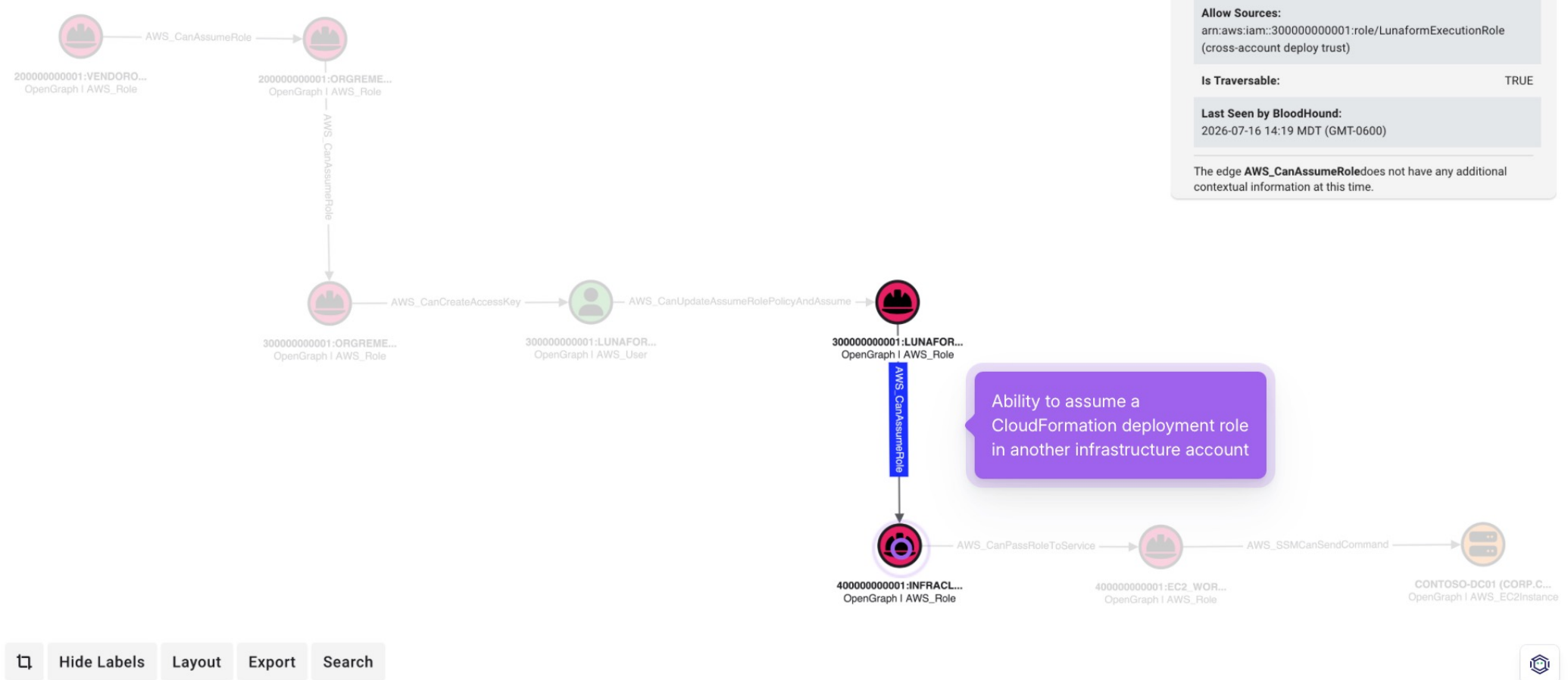
SEARCH

PATHFINDING

CYPHER

200000000001:VENDORORGREADROLE

CONTOSO-DC01 (CORP.CONTOSO.COM)



AWS_CanAssumeRole

Relationship Information

Source Node: 300000000001:LUNAFORMEXECUTIONROLE

Target Node: 400000000001:INFRACLLOUDFORMATIONDEPLOYROLE

Allow Sources:

arn:aws:iam::300000000001:role/LunaformExecutionRole (cross-account deploy trust)

Is Traversable: TRUE

Last Seen by BloodHound:

2026-07-16 14:19 MDT (GMT-0600)

The edge `AWS_CanAssumeRole` does not have any additional contextual information at this time.

SEARCH

PATHFINDING

CYPHER

200000000001:VENDORORGREADROLE

CONTOSO-DC01 (CORP.CONTOSO.COM)

200000000001:VENDORORGREADROLE
OpenGraph | AWS_Role

200000000001:ORGREME...
OpenGraph | AWS_Role

300000000001:ORGREME...
OpenGraph | AWS_Role

300000000001:LUNAFOR...
OpenGraph | AWS_User

300000000001:LUNAFOR...
OpenGraph | AWS_Role

400000000001:INFRACL...
OpenGraph | AWS_Role

400000000001:EC2_WOR...
OpenGraph | AWS_Role

CONTOSO-DC01 (CORP.C...
OpenGraph | AWS_EC2Instance

AWS_CanAssumeRole

AWS_CanAssumeRole

AWS_CanCreateAccessKey

AWS_CanUpdateAssumeRolePolicyAndAssume

AWS_CanAssumeRole

AWS_CanPassRoleToService

AWS_SSMCanSendCommand

Relationship Information

Source Node:
400000000001:INFRACL...
Target Node:
400000000001:EC2_WORKLOAD_ROLE

Allow Sources:
arn:aws:iam::400000000001:role/InfraCloudFormationDeploy...
(iam:PassRole EC2_Workload_Role -> cloudformation StackSet execution)

Has Trust Rewrite Path:
FALSE

Is Traversable:
TRUE

Last Seen by BloodHound:
2026-07-16 14:19 MDT (GMT-0600)

Methods:
[{"service": "cloudformation", "method": "UpdateStackSet", "edge_kind": "AWS_CanPassRoleViaCloudFormation", "pass_role_conditions": "", "requires_trust_update": false}]

Services:
cloudformation

The edge AWS_CanPassRoleToService does not have any additional contextual information at this time.

Hide Labels

Layout

Export

Search

Role can create stacks and pass an EC2 workload role to a service, the attacker can launch compute, query IMDS for temporary credentials, and authenticate as the EC2 workload role

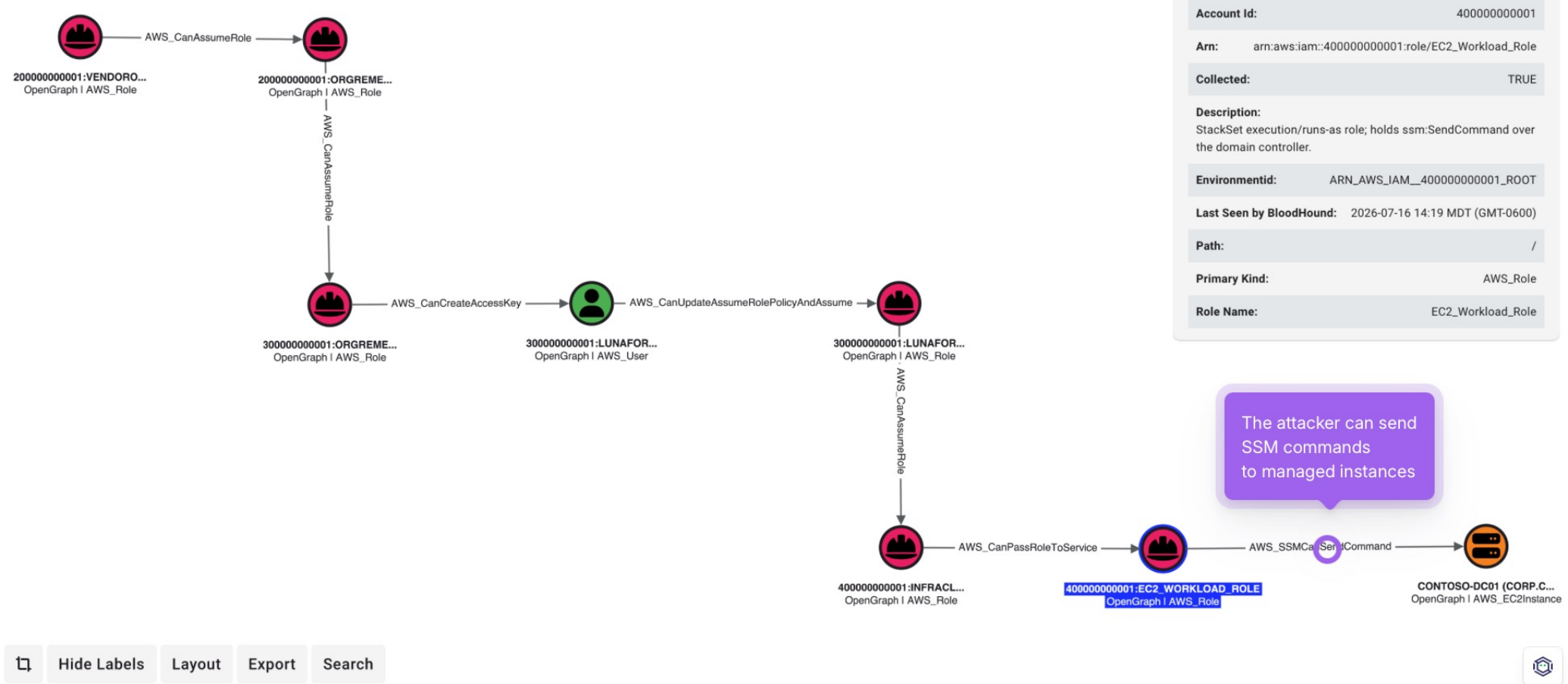
SEARCH

PATHFINDING

CYPHER

200000000001:VENDORORGREADROLE

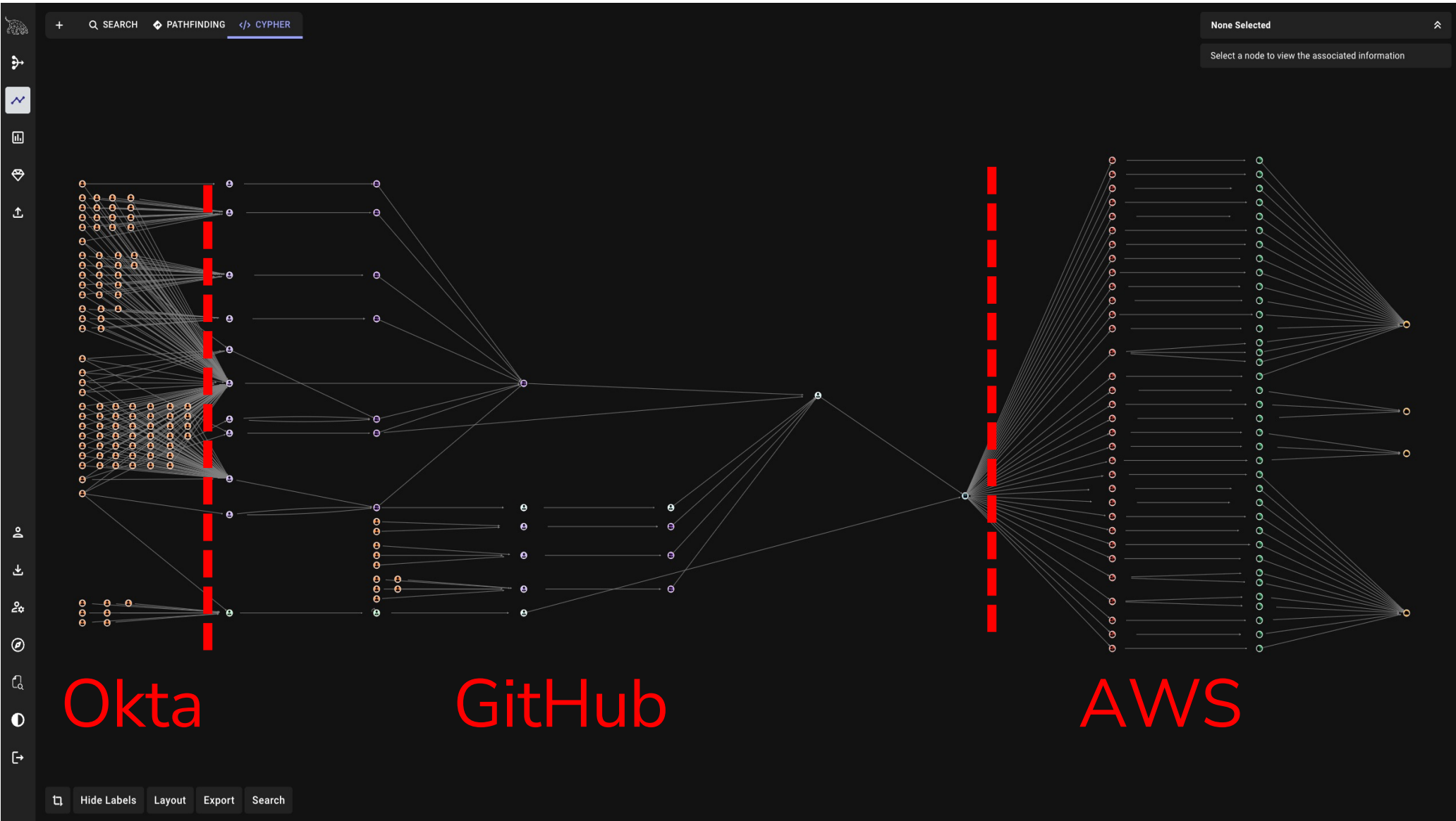
CONTOSO-DC01 (CORP.CONTOSO.COM)



400000000001:EC2_WORKLOAD_ROLE

Object Information

Node Type:	AWS_Role
Object ID:	ARN_AWS_IAM_400000000001_ROLE/EC2_WORKLOAD_ROLE
Account Id:	400000000001
Arn:	arn:aws:iam:400000000001:role/EC2_Workload_Role
Collected:	TRUE
Description:	StackSet execution/runs-as role; holds ssm:SendCommand over the domain controller.
EnvironmentId:	ARN_AWS_IAM_400000000001_ROOT
Last Seen by BloodHound:	2026-07-16 14:19 MDT (GMT-0600)
Path:	/
Primary Kind:	AWS_Role
Role Name:	EC2_Workload_Role



Attack Paths in Entra Agent ID

Why Attack Path Management for AI Agents

Agent security typically a governance problem:

- How many agents exist?
- Who created them?
- Which models do they use?
- Which connections are configured?
- What are they doing?

APM tells us what attackers can do:

- Who can invoke an agent acting as someone else?
- Which public agents act as bridges?
- Which blueprints control identities mapping to Entra service principals?
- Which agents delegate executions to Power Automate flows?
- **Most Importantly: How do all these relationships combine into a path to threaten something critical to the organization?**

How agents are modeled in BloodHound

- **Entra Agent ID:** Agent identity blueprints, tenant-local blueprint principals, agent identities, ownership and administrative control, blueprint-to-identity relationships, and agent identities to Entra service principals.
- **Copilot Studio:** Copilot agents, owners, invocation access, maker-credential identity transitions, and connections and Power Automate flows used by agents.
- **Power Platform and Power Automate:** Flows, flow-to-flow delegation, and connections used by those flows.
- **Azure AI Foundry.** Foundry projects and account-scope role assignments. Foundry agents, project-contained connections, project-scope roles, agent identities, and A2A relationships remain under development.
- **Cross-graph relationships.** Perhaps most importantly, agent identities are connected to their corresponding Entra service principals, allowing attack paths to continue into the existing Entra and Azure graph.

TL;DR

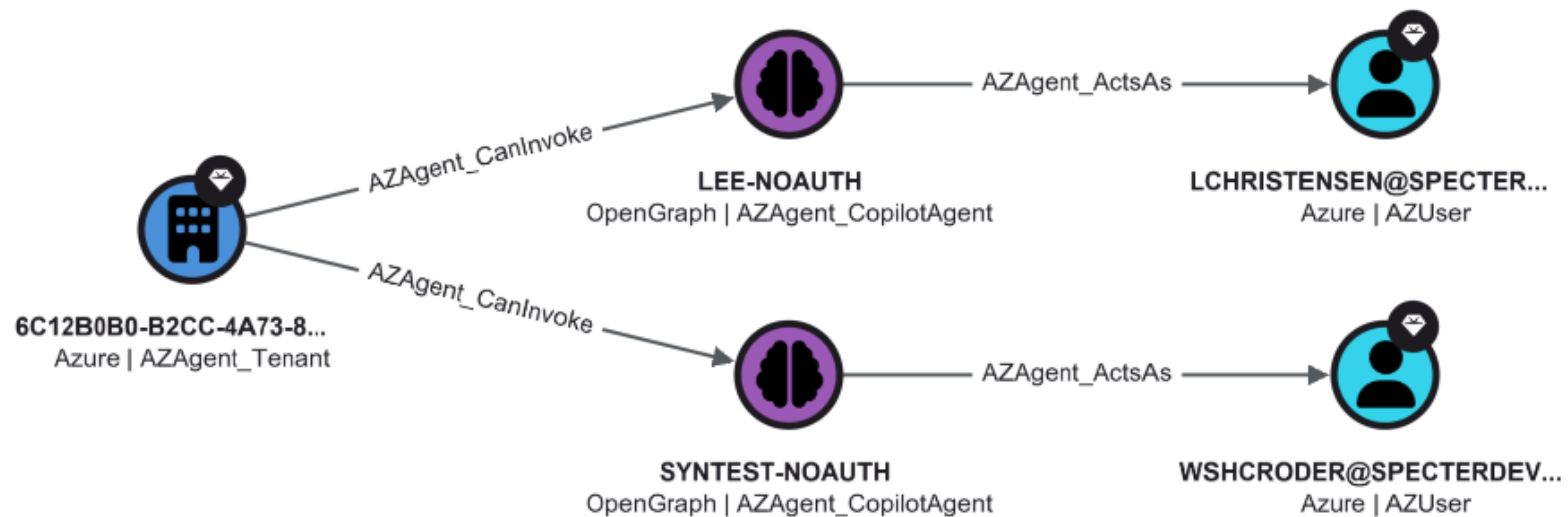
Agents are not modeled as isolated AI applications but as participants in the environment's identity and authorization system.

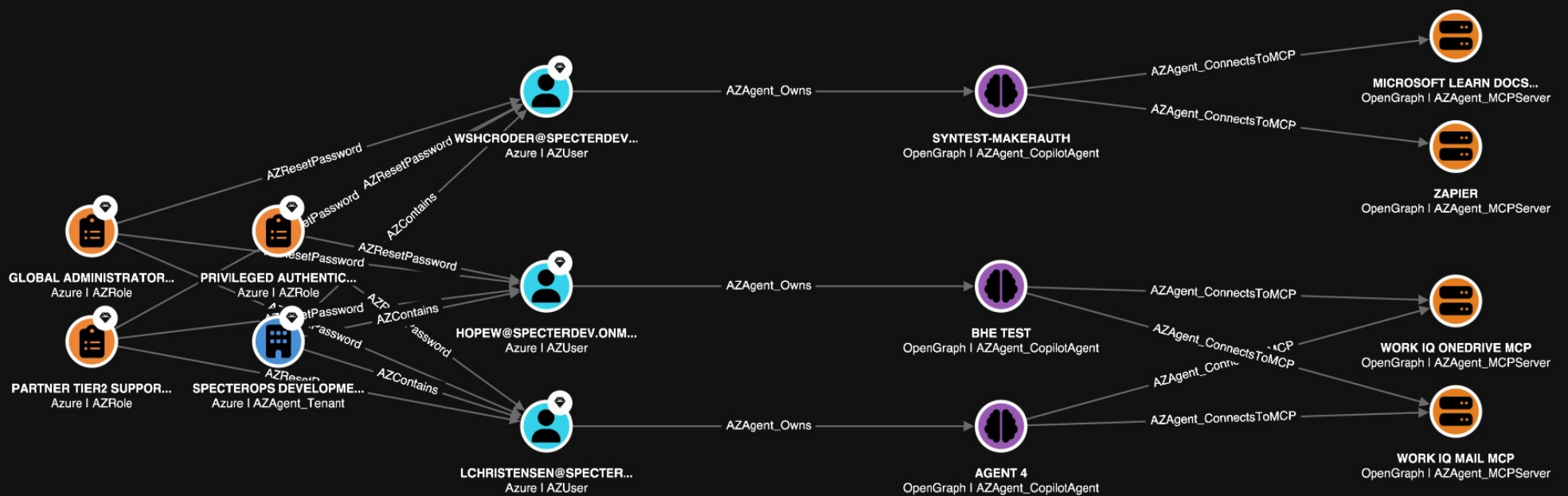
Stop flipping through blades to understand how agent control propagates throughout the system.

The user who invokes the agent may not be the identity that acts.



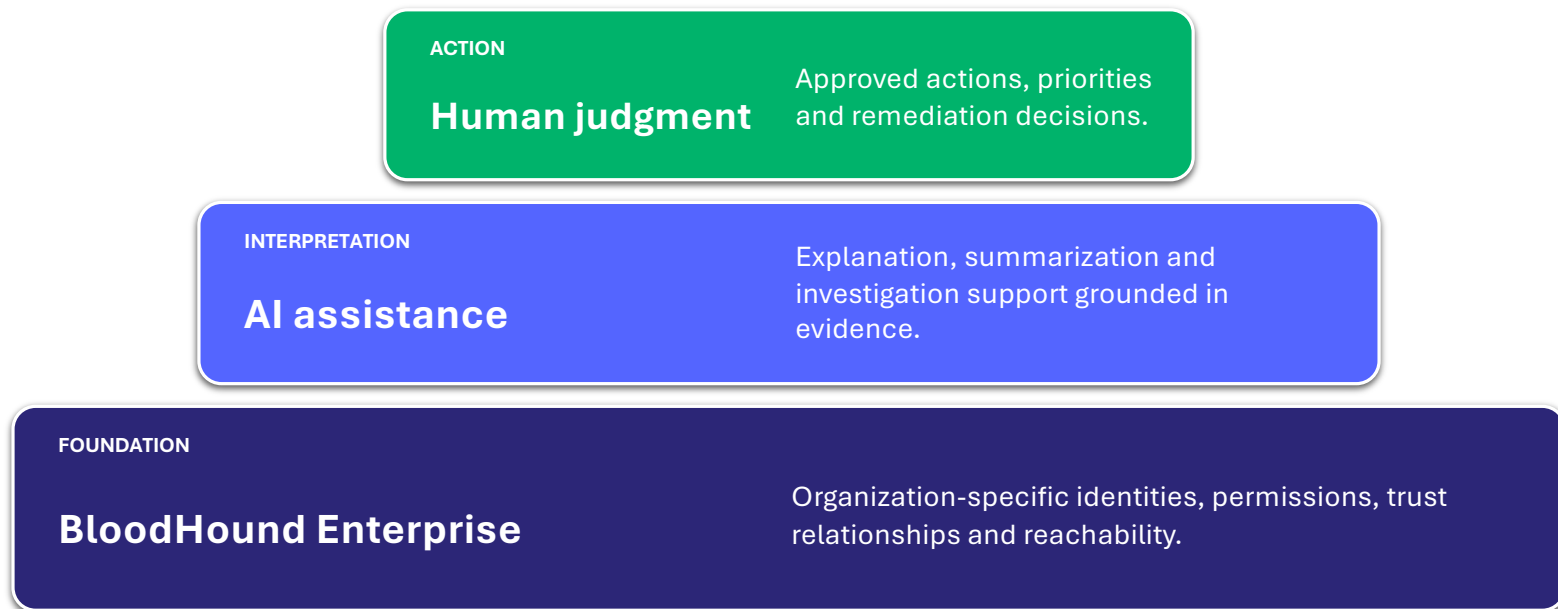
Agents can be invoked by anyone in the tenant





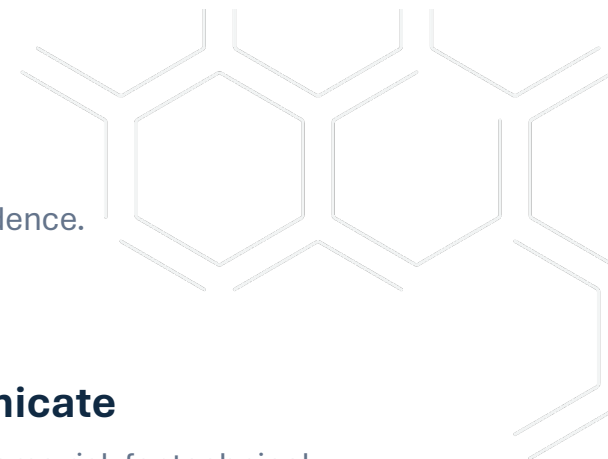
Integrating BloodHound Enterprise in Agent Workflows

AI workflows start with authoritative security context



Attack Path workflows accelerate action

Four practical ways AI assistance can help practitioners work with existing BloodHound evidence.



01

Investigate

Explain a complete attack path in clear, plain language.

02

Communicate

Adapt the same risk for technical, operational, and business audiences.

03

Organize

Surface candidates for Privilege Zone and protected-system review.

04

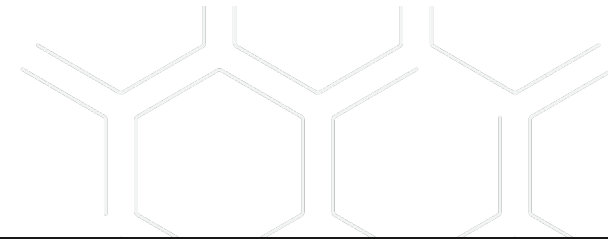
Prioritize

Compare remediation options and their likely effect on attack paths.

AI workflows accelerate action

01 Investigate

Explain a complete attack path in clear, plain language.



explain the top risk in my github environment

Worked for 1m 10s >

The top GitHub risk is **Secret Access Across Privilege Zones**.

- **Observed:** BloodHound reports 25 active repository-to-secret access relationships, including **18 critical**. The finding was confirmed in the latest collection from August 24, 2026.
- **Clearest example:** `PRODUCTS-MOBILE-APP` can access the Tier Zero organization secret `APPSTORE_CONNECT_API_KEY` through an exact `GH_HasSecret` relationship. It also has access to `PROD_DEPLOY_SIGNING_KEY` and `PRODUCTS_PACKAGE_REGISTRY_TOKEN`.
- **Why it matters:** Someone who gains control of that repository or a workflow capable of consuming its secrets could potentially obtain credentials used for application publishing, signing, or package distribution. That could turn repository compromise into a production supply-chain incident.
- **Blast radius:** Similar exposure affects `SIEM_INGEST_API_KEY` across multiple corporate repositories. Several Infra findings involve `ARM_CLIENT_ID` and `ARM_TENANT_ID`; those are normally identifiers rather than secret credentials and should be reclassified after verification.
- **Important limitation:** BloodHound proves that GitHub makes the secrets available to those repositories. It does **not** prove the values were extracted, exposed in logs, or abused.

The most important fix is to remove production credentials from broad organization scope. Restrict them to selected repositories—ideally protected GitHub environments with required reviewers and release-branch restrictions—then rotate genuine credentials after validating the narrowed workflows.

AI workflows accelerate action

02

Communicate

Adapt the same risk for technical, operational, and business audiences.

Give me a friendly explanation i can take to my business counterparts to explain the risk

Here's a business-friendly explanation you can use:

We found that several GitHub repositories have access to highly sensitive production credentials, including credentials used for application publishing, software signing, package distribution, and security-system integrations.

This does not mean those credentials have been stolen or misused. The concern is that access is broader than necessary. If one of these repositories or its automated build process were compromised, an attacker might be able to use the connected credential to affect a production service or distribute software that appears legitimate.

A useful analogy is giving multiple project teams keys to the production vault when only the release team needs them. Every additional key increases the chance that one is lost or misused.

We recommend limiting each credential to the specific repository and release process that requires it, adding approval before production credentials become available, and replacing existing credentials after the access has been narrowed. This reduces the potential impact of a repository compromise without stopping normal development.

The key message is: **this is an excessive-access risk, not evidence of an active breach.** Addressing it reduces the chance that an ordinary development-system incident becomes a customer-facing or supply-chain event.

AI workflows accelerate action

03

Organize

Surface candidates for Privilege Zone and protected-system review.

Worked for 1m 50s >

I recommend three additional GitHub privilege zones, with one conditional zone pending validation. These are proposed boundaries, not final classifications.

Priority	Proposed zone	Principals to include	Principals to keep outside
1	Mobile Release & Code Signing	<code>PRODUCTS-MOBILE-APP</code> ; its production release environment/workflow; <code>APPSTORE_CONNECT_API_KEY</code> ; <code>PROD_DEPLOY_SIGNING_KEY</code> ; <code>PRODUCTS_PACKAGE_REGISTRY_TOKEN</code> ; approved release-role containers	The repository's broad <code>READ</code> role and ordinary contributors
2	Security Detection & SIEM	<code>SECURITY-DETECTIONS</code> ; <code>SIEM_INGEST_API_KEY</code> ; its publishing workflow/environment; dedicated security-maintainer roles	<code>HR-ONBOARDING-SCRIPTS</code> unless it has a documented need; possibly <code>CORP-IT-AUTOMATION</code>
3	GitHub Identity Administration	<code>CYNTHIA-GREEN_KNEXUS</code> if it has organization-owner, app, secret, or identity-management authority; relevant owner/admin role containers	The upstream Okta identity and ordinary GitHub users
4	Cloud Infrastructure Control Plane	Initially review <code>IDENTITY-AUTOMATION</code> , <code>TERRAFORM-MODULES</code> , <code>INCIDENT-RESPONSE-AUTOMATION</code> , <code>PLATFORM-RUNBOOKS</code> , <code>K-NEXUSGLOBAL-INFRA</code> , and <code>K-NEXUS-GLOBAL-INFRA</code>	Repositories that consume only Azure identifiers and cannot change infrastructure

AI workflows accelerate action

04

Prioritize

Compare remediation options and their likely effect on attack paths.

for our top risk, compare remediation options

Worked for 1m 16s >

Finding summary

- **[Observed]** `PRODUCTS-MOBILE-APP` can access five credentials, including Tier Zero organization secrets `APPSTORE_CONNECT_API_KEY`, `PROD_DEPLOY_SIGNING_KEY`, and `PRODUCTS_PACKAGE_REGISTRY_TOKEN`.
- **[Observed]** The repository has one modeled workflow, `BUILD-MOBILE`, and only a `STAGING` environment is visible.
- **[Observed]** The repository's `READ` role has a critical `GH_CanPwnRequest` relationship, while its `ADMIN` role can bypass branch protection.
- **[Derived]** The principal risk is that ordinary repository or pull-request exposure can potentially reach production publishing and signing credentials.

Scores below use 1–5, where 5 is strongest or most costly.

Option	Risk reduction	Root-cause depth	Durability	Operational cost	Estimated time
Narrow organization-secret access	3	2	3	1	15–30 minutes per secret
Move credentials to a protected production environment	5	3	5	3	1–3 hours
Refactor the vulnerable workflow	5	5	5	3–4	Half-day to two days
Rotate and split credentials	3	2	4	3–5	Varies by credential
Expand the Code Signing zone	0	0	2	1	Under an hour

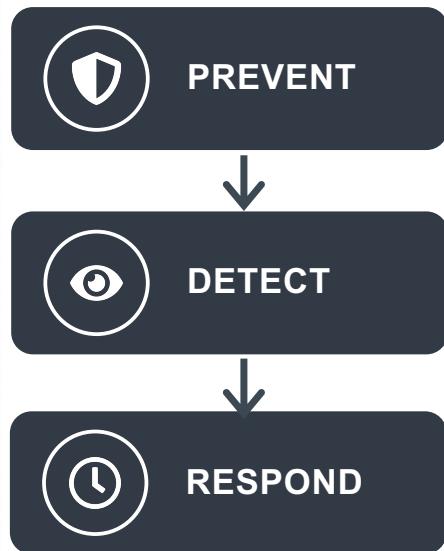


Eliminating attack paths is our mission

The security model must change

TRADITIONAL SECURITY MODEL

Reactive. Human-paced.

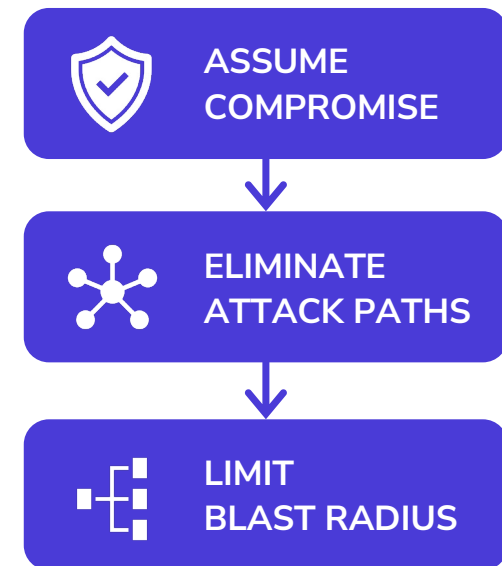


MACHINE
SPEED
ATTACKS



AI-ERA SECURITY MODEL

Proactive. Architecture-led.



As timelines shrink,
resilience depends on containment.

BloodHound Enterprise

Attack Path Management across AI and Hybrid Environments



Hybrid Infrastructure

Identity and resources span cloud and on-premises environments.



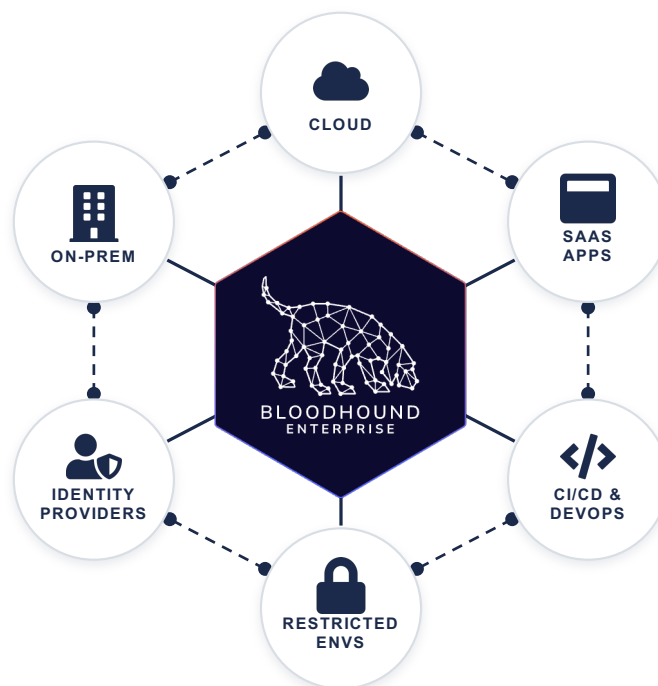
Human, Non-Human Identities & Agents

People, service accounts, workloads, devices, and agents all introduce risk.



Cross-Environment Trust

Complex trust relationships and entitlements cross infrastructure boundaries.



Continuous Attack Path Analysis

Continuously analyze attack paths to understand and reduce risk.



Consistent Identity Visibility

Maintain consistent identity visibility across all environments and identity types.



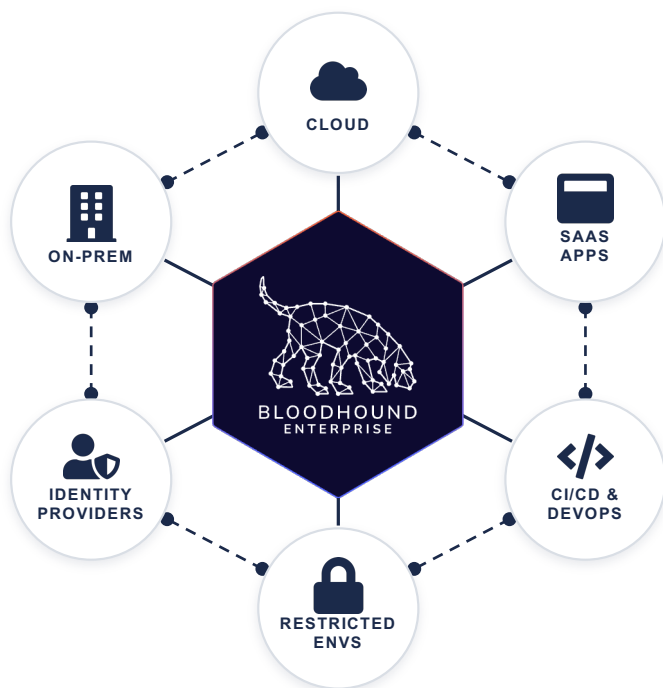
Cross-Environment Coverage

Correlate and analyze identity relationships across hybrid infrastructure.



BloodHound Enterprise

Use Integrations to manage attack paths with existing workflows



Centralize data and alerts

Splunk SIEM, Microsoft Sentinel, Google SecOps, Axonius, Rapid7, Attack Forge

Remediations and change management

ServiceNow Security Incident Response, ServiceNow Vulnerability Response, Atlassian JIRA

Automate remediations and enrichments

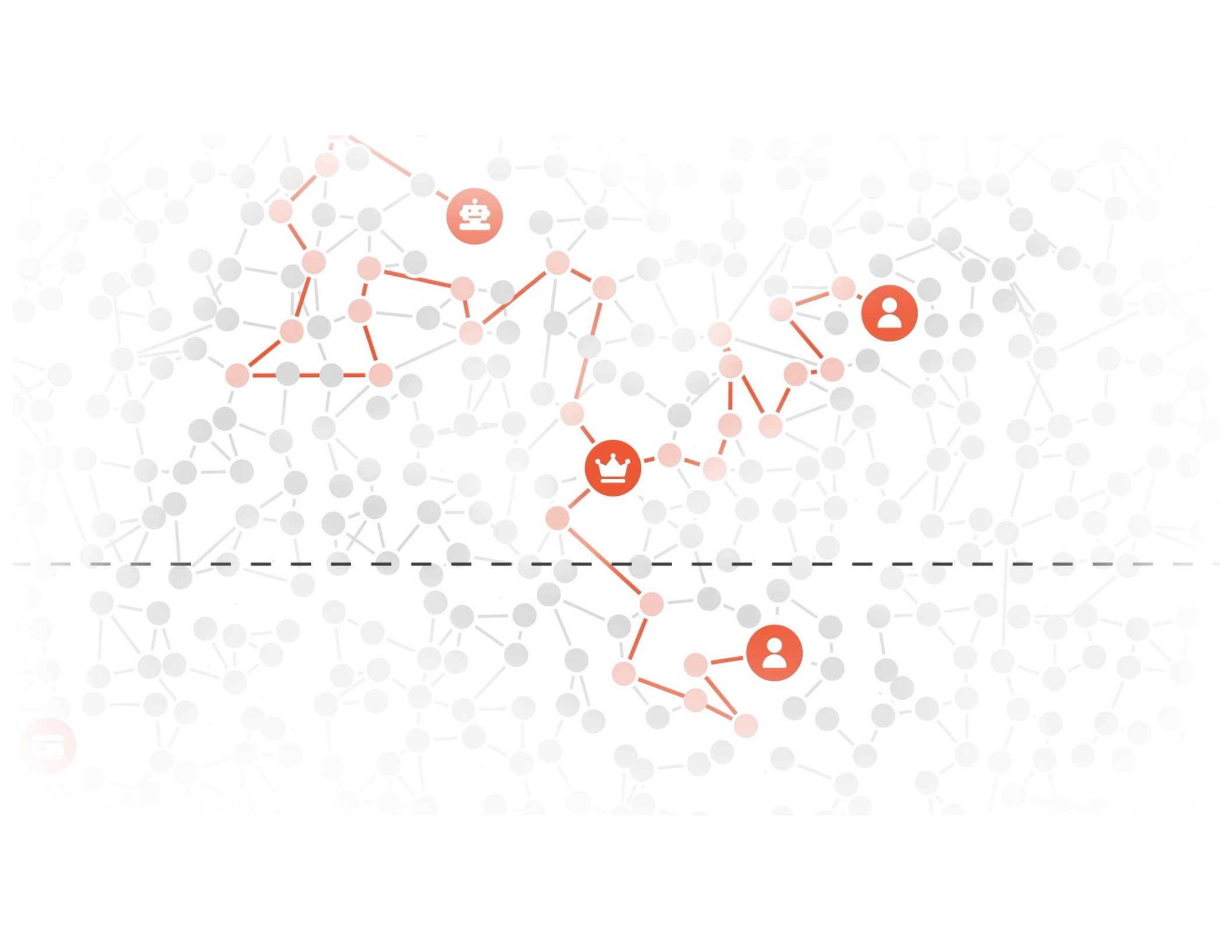
Tines, Splunk SOAR, Palo Alto XSOAR, Quest Change Auditor

Agentic workflows and natural language

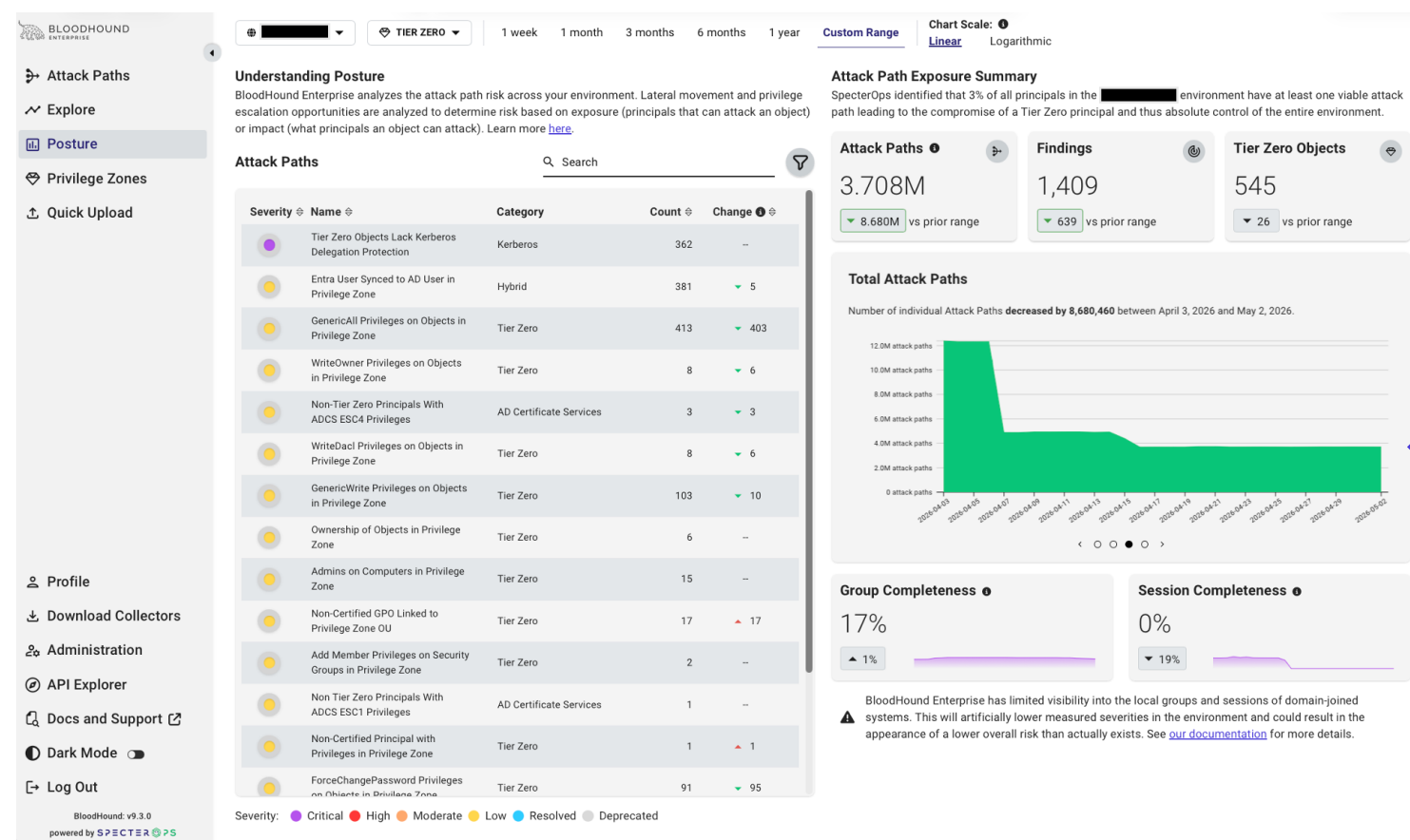
BloodHound Enterprise MCP (beta)

Enterprise Single Sign On

Cisco DUO SSO, Entra ID SSO, Okta SSO, SAML



Real results



Real business and operational value

“BloodHound Enterprise goes beyond detection: It continuously maps and prioritizes the most exploitable paths, empowering engineering teams to respond decisively... before adversaries can act.”



Jason Krolak*

Principal Group Engineering Manager



FORTUNE 100 FOOD & BEV

54% reduction

in exposure in 6 months

FORTUNE 100 BANK

100% elimination

of Tier 0 attack paths in 6 months

FORTUNE 100 HEALTHCARE

90% reduction

in attack paths in 18 months

Thank you

specterops.io

